MITRE ATLAS | AML.CS0015 - Compromised PyTorch Dependency Chain

Entry Information

ID:
AML.CS0015

Type:
Case-Study

Name:
Compromised PyTorch Dependency Chain

URL:
https://atlas.mitre.org/studies/AML.CS0015/

Incident Date:
2022-12-25

Target:
PyTorch

Actor:
Unknown

Description

Linux packages for PyTorch's pre-release version, called Pytorch-nightly, were compromised from December 25 to 30, 2022 by a malicious binary uploaded to the Python Package Index (PyPI) code repository. The malicious binary had the same name as a PyTorch dependency and the PyPI package manager (pip) installed this malicious package instead of the legitimate one.

This supply chain attack, also known as "dependency confusion," exposed sensitive information of Linux machines with the affected pip-installed versions of PyTorch-nightly. On December 30, 2022, PyTorch announced the incident and initial steps towards mitigation, including the rename and removal of `torchtriton` dependencies.

Attack Procedure:
[AML.T0010.001] AI Software: A malicious dependency package named `torchtriton` was uploaded to the PyPI code repository with the same package name as a package shipped with the PyTorch-nightly build. This malicious package contained additional code that uploads sensitive data from the machine.
The malicious `torchtriton` package was installed instead of the legitimate one because PyPI is prioritized over other sources. See more details at [this GitHub issue](https://github.com/pypa/pip/issues/8606).
[AML.T0037] Data from Local System: The malicious package surveys the affected system for basic fingerprinting info (such as IP address, username, and current working directory), and steals further sensitive data, including:
- nameservers from `/etc/resolv.conf`
- hostname from `gethostname()`
- current username from `getlogin()`
- current working directory name from `getcwd()`
- environment variables
- `/etc/hosts`
- `/etc/passwd`
- the first 1000 files in the user's `$HOME` directory

- `$HOME/.gitconfig`
- `$HOME/.ssh/*.`

[AML.T0025] Exfiltration via Cyber Means: All gathered information, including file contents, is uploaded via encrypted DNS queries to the domain `*[dot]h4ck[dot]cfd`, using the DNS server `wheezy[dot]io`.

References

- PyTorch statement on compromised dependency — https://pytorch.org/blog/compromised-nightly-dependency/

- Analysis by BleepingComputer — https://www.bleepingcomputer.com/news/security/pytorch-discloses-malicious-dependency-chain-compromise-over-holidays/